

Vulnerability Assessment Report

Project Name: FUTURE_CS_01

Target Website: <https://httpbin.org>

Assessment Type: Passive Security Assessment (Read-Only)

Date: 16 May 2026

Prepared By: Archana S

Executive Summary

A passive vulnerability assessment was conducted on the public website <https://httpbin.org> using Nmap, OWASP ZAP, and Browser Developer Tools.

The purpose of this assessment was to identify common security weaknesses without performing any intrusive or harmful actions.

The assessment identified several low- and medium-risk issues, including:

- Server version disclosure
- Missing security headers
- Cookie security recommendations

No exploitation or active attacks were performed.

Scope of Assessment

Included

- Publicly accessible pages
- HTTP/HTTPS service detection
- Passive vulnerability scanning
- Security header inspection
- Cookie inspection

Excluded

- Exploitation
 - Authentication bypass
 - Brute force attacks
 - Denial-of-Service (DoS)
 - Data modification
-

Tools Used

Tool	Purpose
Nmap	Detect open ports and exposed services
OWASP ZAP	Passive vulnerability scanning
Browser Developer Tools	Inspect headers and cookies
Canva	Design professional PDF report

Methodology

1. Selected a legal public website for testing.
2. Performed service detection using Nmap.
3. Conducted passive scanning with OWASP ZAP.
4. Reviewed HTTP security headers.
5. Classified findings by risk level.
6. Provided remediation recommendations.

Nmap Scan Results

Command Used

```
nmap -sV httpbin.org -oN nmap_scan.txt
```

Results Summary

Port	Protocol	Service	Version
80	TCP	HTTP	Gunicorn 19.9.0
443	TCP	HTTPS	Gunicorn 19.9.0

Observation

The server reveals its software name and version (`Gunicorn 19.9.0`). This is an information disclosure issue.

OWASP ZAP Findings Summary

OWASP ZAP passive scanning identified several informational and low-risk alerts related to security hardening.

Typical findings included:

- Missing Content-Security-Policy header
 - Missing X-Frame-Options header
 - Server information disclosure
 - Cookie security recommendations
-

Detailed Findings

Finding 1: Server Version Disclosure

Risk Level: Low

Description

The web server discloses its software and version (`Gunicorn 19.9.0`) during network communication.

Business Impact

Attackers can use this information to search for known vulnerabilities affecting the disclosed version.

Recommendation

Configure the web server to hide version information.

Finding 2: Missing Content-Security-Policy Header

Risk Level: Medium

Description

The application does not define a Content-Security-Policy (CSP) header.

Business Impact

Without CSP, malicious scripts may execute if a cross-site scripting vulnerability exists.

Recommendation

Implement a restrictive Content-Security-Policy header.

Example:

```
Content-Security-Policy: default-src 'self';
```

Finding 3: Missing X-Frame-Options Header

Risk Level: Low

Description

The application does not define an X-Frame-Options header.

Business Impact

The website could be embedded inside another website, increasing clickjacking risk.

Recommendation

Add one of the following headers:

```
X-Frame-Options: DENY
```

or

```
X-Frame-Options: SAMEORIGIN
```

Finding 4: Cookie Security Flags Missing or Recommended

Risk Level: Medium

Description

Some cookies may not use the `Secure` and `HttpOnly` flags.

Business Impact

Cookies may be exposed to interception or client-side scripts.

Recommendation

Configure cookies with:

```
Set-Cookie: sessionid=abc123; Secure; HttpOnly; SameSite=Lax
```

Risk Summary

Risk Level	Count
High	0
Medium	2
Low	2

Recommended Remediation Priority

1. Implement Content-Security-Policy.
 2. Configure Secure and HttpOnly cookie flags.
 3. Add X-Frame-Options.
 4. Hide server version details.
-

Evidence Collected

- evidence/nmap_scan.txt
 - evidence/zap_report.html
 - evidence/screenshots/nmap_output.png
 - evidence/screenshots/zap_alerts.png
-

Conclusion

The target website is functional and generally well-configured, but several common hardening opportunities were identified.

The most important improvements are implementing Content-Security-Policy and strengthening cookie security.

Addressing these issues will reduce exposure to cross-site scripting, clickjacking, and information disclosure risks.

Appendix A: Repository Structure

```
FUTURE_CS_01/  
├─ README.md  
├─ report/  
│   └─ Vulnerability_Assessment_Report.pdf  
└─ evidence/  
    ├─ nmap_scan.txt  
    ├─ zap_report.html  
    └─ screenshots/  
        ├─ nmap_output.png  
        └─ zap_alerts.png
```

Appendix B: README Summary

```
# FUTURE_CS_01 - Vulnerability Assessment Report  
  
## Target Website  
https://httpbin.org  
  
## Scope  
Passive security assessment only  
  
## Tools Used  
- Nmap  
- OWASP ZAP  
- Browser Developer Tools  
- Canva
```